Reporte de Incidente SOC - Hammered Lab

Índice

1. Resumen Ejecutivo
2. Alcance y fuentes de datos
3. Acceso inicial
4. Nivel de privilegio
5. Mecanismos de persistencia
6. Evasión de defensa
7. Actividad de descubrimiento
8. Indicadores de mando y control
9. Problemas de seguridad de la base de datos
10. Mapeo al Marco MITRE ATT&CK
11. Conclusiones

1. Resumen Ejecutivo

El análisis de múltiples fuentes de logs evidenció un compromiso completo del sistema. Se identificó un patrón claro de ataque de fuerza bruta contra el servicio SSH, seguido de accesos exitosos utilizando credenciales válidas del usuario root.

Posteriormente, el atacante ejecutó acciones típicas de post-explotación, incluyendo modificación de firewall, instalación de herramientas de reconocimiento y creación de cuentas para persistencia. La presencia de configuraciones inseguras en la base de datos (cuentas root sin contraseña) incrementó significativamente el impacto del incidente.

Conclusión técnica: ataque exitoso con control total del sistema.

---

2. Alcance y fuentes de datos

El análisis se basó en correlación de múltiples logs del sistema:

- `auth.log` → evidencia directa de autenticación, fuerza bruta, reglas añadidas del firewall (iptables) y creación de usuarios
- `daemon.log` → eventos críticos de servicios (MySQL warnings)
- `apt/term.log` → instalación de herramientas por el atacante
- `apache2/www-access.log` → actividad web y User-Agent
- `dmesg` → contexto del sistema (versión y año)

La correlación entre logs permite reconstruir el ataque completo (timeline).

---

3. Acceso inicial

El análisis del archivo auth.log revela una secuencia clara de eventos asociados a intentos de autenticación fallidos mediante el servicio SSH. Se identificaron múltiples entradas del tipo:

`pam_unix(sshd:auth): authentication failure`

La siguiente imagen muestra la cantidad de intentos de autenticación fallidos que obtuvo cada dirección IP externa y a nombres de usuario que intentaron acceder:

```
checho@Windows-localhost:~/Hammered$ grep "authentication failure" auth.log | awk '{print $14}' | sort | uniq -c
     22 rhost=
      1 rhost=10.0.1.4
     97 rhost=114.80.166.219
    180 rhost=116.6.19.70
      1 rhost=12.172.224.140
   1435 rhost=121.11.66.70
     34 rhost=122.102.64.54
      7 rhost=122.165.9.200
    513 rhost=122.226.202.12
    650 rhost=124.207.117.9
    158 rhost=124.51.108.68
    113 rhost=125.235.4.130
      2 rhost=190.166.87.164
     10 rhost=190.4.21.190
     26 rhost=200.72.254.54
     97 rhost=201.64.234.2
      1 rhost=208.80.69.74
    121 rhost=209.59.222.166
    455 rhost=211.154.254.248
    427 rhost=217.15.55.133
      9 rhost=218.56.61.114
     28 rhost=219.139.243.236
   9259 rhost=219.150.161.20
     15 rhost=220.170.79.247
    646 rhost=222.169.224.197
      3 rhost=222.240.223.88
   1573 rhost=222.66.204.246
    263 rhost=58.17.30.49
     51 rhost=59.46.39.148
     13 rhost=61.151.246.140
    213 rhost=61.168.227.12
    306 rhost=65.208.122.48
      1 rhost=65.88.2.5
      1 rhost=76-191-195-140.dsl.dynamic.sonic.net
      4 rhost=78.38.27.21
   3037 rhost=8.12.45.242
      2 rhost=83.216.63.124
      3 rhost=89.46.213.128
      1 rhost=94.52.185.9
      2 rhost=adsl-71-132-129-212.dsl.pltn13.pacbell.net
      3 rhost=cpe-24-94-90-96.hawaii.res.rr.com
    168 rhost=d192-24-91-113.try.wideopenwest.com
```

```
      2 rhost=host-188-131-23-37.hspa.orange.md
    145 rhost=jp.user2pastoreinc.com
     79 rhost=mail.mediamonitors.com.pk
    171 rhost=system.firefoxlanka.com
      5 tty=ssh
```

Estos registros indican que el servicio sshd recibió múltiples intentos de autenticación fallidos, por lo que este patron es consistente con un ataque de fuerza bruta.

Correlación de eventos

Posteriormente, se identifican eventos de autenticación exitosa mediante las siguientes direcciones IPs:

```
checho@Windows-localhost:~/Hammered$ grep "Accepted password for" auth.log | awk '{print $11}' | sort | uniq -c
     14 10.0.1.2
      4 10.0.1.4
      2 121.11.66.70
      2 122.226.202.12
      1 151.81.204.141
      1 151.81.205.100
      1 151.82.3.201
      1 166.129.196.88
      1 188.131.22.69
      4 188.131.23.37
     23 190.166.87.164
      1 190.167.70.87
      3 190.167.74.184
      3 192.168.126.1
      1 193.1.186.197
      1 201.229.176.217
      2 208.80.69.69
      1 208.80.69.70
      7 208.80.69.74
      4 219.150.161.20
      1 222.169.224.197
      1 222.66.204.246
      1 61.168.227.12
      2 65.195.182.120
      6 65.88.2.5
      1 67.164.72.181
      5 71.132.129.212
     22 76.191.195.140
      2 94.52.185.9
```

El evento confirma:

- Autenticación exitosa
- Uso del usuario root
- Acceso remoto vía SSH
- Origen desde una IP externa

---

4. Nivel de privilegio

El análisis de los registros de autenticación (auth.log) evidencia que los accesos exitosos al sistema fueron realizados directamente utilizando la cuenta privilegiada **root**:

```
checho@Windows-localhost:~/Hammered$ grep "Accepted password" auth.log | grep root
Mar 29 13:27:26 app-1 sshd[21556]: Accepted password for root from 10.0.1.2 port 51784 ssh2
Apr 19 05:41:44 app-1 sshd[8810]: Accepted password for root from 219.150.161.20 port 51249 ssh2
Apr 19 05:42:27 app-1 sshd[9031]: Accepted password for root from 219.150.161.20 port 40877 ssh2
Apr 19 05:55:20 app-1 sshd[12996]: Accepted password for root from 219.150.161.20 port 55545 ssh2
Apr 19 05:56:05 app-1 sshd[13218]: Accepted password for root from 219.150.161.20 port 36585 ssh2
Apr 19 10:45:36 app-1 sshd[28030]: Accepted password for root from 222.66.204.246 port 48208 ssh2
Apr 19 11:03:44 app-1 sshd[30277]: Accepted password for root from 201.229.176.217 port 54465 ssh2
Apr 19 11:15:26 app-1 sshd[30364]: Accepted password for root from 190.167.70.87 port 49497 ssh2
Apr 19 22:37:24 app-1 sshd[2012]: Accepted password for root from 190.166.87.164 port 50753 ssh2
Apr 19 22:54:06 app-1 sshd[2149]: Accepted password for root from 190.166.87.164 port 51101 ssh2
Apr 19 23:02:25 app-1 sshd[2210]: Accepted password for root from 190.166.87.164 port 51303 ssh2
Apr 20 06:13:03 app-1 sshd[26712]: Accepted password for root from 121.11.66.70 port 33828 ssh2
Apr 21 11:51:38 app-1 sshd[2649]: Accepted password for root from 193.1.186.197 port 38318 ssh2
Apr 21 11:56:37 app-1 sshd[2686]: Accepted password for root from 151.81.205.100 port 54272 ssh2
Apr 22 01:30:27 app-1 sshd[4877]: Accepted password for root from 151.82.3.201 port 49249 ssh2
Apr 22 06:41:38 app-1 sshd[5876]: Accepted password for root from 151.81.204.141 port 59064 ssh2
Apr 22 11:02:15 app-1 sshd[7940]: Accepted password for root from 222.169.224.197 port 45356 ssh2
Apr 23 03:11:03 app-1 sshd[13633]: Accepted password for root from 122.226.202.12 port 40892 ssh2
Apr 23 03:20:41 app-1 sshd[13930]: Accepted password for root from 122.226.202.12 port 40209 ssh2
Apr 24 11:36:19 app-1 sshd[24436]: Accepted password for root from 121.11.66.70 port 58832 ssh2
Apr 24 15:28:37 app-1 sshd[31338]: Accepted password for root from 61.168.227.12 port 43770 ssh2
Apr 24 16:33:36 app-1 sshd[31845]: Accepted password for root from 188.131.22.69 port 1844 ssh2
Apr 24 19:15:54 app-1 sshd[32299]: Accepted password for root from 190.167.74.184 port 60992 ssh2
Apr 25 10:38:56 app-1 sshd[9560]: Accepted password for root from 94.52.185.9 port 59821 ssh2
Apr 26 04:42:55 app-1 sshd[20096]: Accepted password for root from 188.131.23.37 port 3527 ssh2
Apr 26 04:59:02 app-1 sshd[20491]: Accepted password for root from 188.131.23.37 port 3561 ssh2
Apr 26 08:47:28 app-1 sshd[23501]: Accepted password for root from 188.131.23.37 port 4271 ssh2
Apr 26 08:51:50 app-1 sshd[23542]: Accepted password for root from 188.131.23.37 port 4280 ssh2
```

Este tipo de evento confirma que:

- La autenticación fue exitosa
- Se utilizó el usuario root, que posee privilegios máximos
- El acceso se realizó de forma remota mediante SSH

A diferencia de muchos escenarios de intrusión donde el atacante compromete primero una cuenta de bajo privilegio y luego realiza una escalación de privilegios, en este caso se observa que **el acceso inicial ya se realizó con privilegios administrativos completos**.

todas las acciones posteriores (persistencia, evasión, reconocimiento) se ejecutaron con privilegios root.

---

5. Mecanismos de persistencia

El análisis de los registros de autenticación (auth.log) permitió identificar la ejecución del comando **useradd**, utilizado para la creación de una nueva cuenta en el sistema:

```
Apr 25 10:41:44 app-1 useradd[9596]: new group: name=fido, GID=1004
Apr 25 10:41:44 app-1 useradd[9596]: new user: name=fido, UID=0, GID=1004, home=/home/fido, shell=/bin/sh
Apr 26 04:43:15 app-1 useradd[20115]: new user: name=wind3str0y, UID=1004, GID=1005, home=/home/wind3str0y, shell=/bin/bash
```

Este registro evidencia que:

- Se creó un nuevo usuario en el sistema (**wind3str0y**)

- Se le asignó un **UID válido (1004)** → usuario normal
- Se generó un directorio home propio (**/home/wind3str0y**)
- Se configuró un intérprete de comandos interactivo (**/bin/bash**)

Esto permite inferir con alto grado de confianza que la cuenta fue creada por el atacante como mecanismo de persistencia.

Capacidades que otorga esta cuenta

Debido a la configuración observada:

- El usuario tiene una **shell interactiva (/bin/bash)**
- Puede iniciar sesión vía SSH
- Puede ejecutar comandos manualmente
- Puede ser utilizado como punto de entrada encubierto

Correlación con el ataque

Este evento ocurre después de:

- Acceso exitoso como root
- Modificaciones del sistema

---

6. Evasión de defensa

El análisis de los registros del sistema (**auth.log**) evidencia la ejecución de múltiples comandos con privilegios elevados relacionados con la configuración del firewall mediante **iptables**, como se observa en los siguientes eventos:

```
Apr 24 19:25:37 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -L
Apr 24 20:03:06 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p ssh -dport 2424 -j ACCEPT
Apr 24 20:03:44 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp -dport 53 -j ACCEPT
Apr 24 20:04:13 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p udp -dport 53 -j ACCEPT
Apr 24 20:06:22 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp --dport ssh -j ACCEPT
Apr 24 20:11:00 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp --dport 53 -j ACCEPT
Apr 24 20:11:08 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp --dport 113 -j ACCEPT
```

Estas instrucciones indican que el atacante modificó activamente la política de filtrado de paquetes del sistema, específicamente la cadena **INPUT**, la cual controla el tráfico entrante.

Acciones observadas:

1. Apertura de puerto no estándar (2424)

```
Apr 24 20:03:06 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p ssh -dport 2424 -j ACCEPT
```

El puerto 2424 no es un puerto común para servicios legítimos, podría haber sido habilitado para acceso remoto alternativo, servicio backdoor o evasión de monitoreo (evitar puerto 22)

2. Habilitación explícita de SSH

```
Apr 24 20:06:22 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp --dport ssh -j ACCEPT
```

- Se asegura que el acceso SSH permanezca disponible
- Evita bloqueos por configuraciones previas
- Garantiza acceso continuo en el sistema

3. Apertura de puerto 53 (TCP y UDP)

```
Apr 24 20:03:44 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp -dport 53 -j ACCEPT
Apr 24 20:04:13 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p udp -dport 53 -j ACCEPT
```

- El puerto 53 corresponde a DNS
- Apertura en TCP y UDP es poco común en configuraciones básicas

Estas modificaciones no corresponden a tareas administrativas rutinarias, sino a un patrón claro de manipulación del entorno para:

- **Mantener acceso persistente**: Asegurando conectividad entrante y evitando restricciones del firewall
- **Crear canales alternativos de acceso**: Uso de puertos no estándar (2424) y evasión de controles tradicionales
- **Facilitar comunicación encubierta**: La apertura del puerto 53 sugiere posible uso de DNS como canal de comunicación **(DNS tunneling)**

Correlación con otras actividades del atacante:

Estas acciones se producen después del acceso root exitoso, lo que permite modificar reglas sin restricciones.

---

7. Actividad de descubrimiento

El análisis del archivo **/var/log/apt/term.log** revela la instalación de una herramienta de escaneo de red por parte del atacante:

```
checho@Windows-localhost:~/Hammered$ grep -i "nmap" apt/term.log
Selecting previously deselected package nmap.
Unpacking nmap (from .../archives/nmap_4.53-3_amd64.deb) ...
Setting up nmap (4.53-3) ...
checho@Windows-localhost:~/Hammered$
```

Este registro corresponde a la fase final del proceso de instalación de un paquete mediante APT. Las líneas previas (ya observadas) confirman:

- El paquete **nmap** fue seleccionado e instalado manualmente

- No estaba presente previamente en el sistema
- La instalación ocurrió posterior al acceso inicial

nmap no forma parte de servicios básicos del sistema, su instalación es intencional

Objetivos del atacante al instalar nmap

El atacante probablemente utilizó esta herramienta para:

1. Reconocimiento interno

- Identificar hosts en la red local
- detectar servidores adicionales
- mapear la infraestructura

2. Enumeración de servicios

- Identificar puertos abiertos
- Descubrir servicios vulnerables

3. Preparación para movimiento lateral

- Encontrar nuevos objetivos dentro la red
- Planificar expansion del ataque
- Identificar posibles vectores adicionales

---

8. Indicadores de mando y control

El análisis de los registros de acceso web (apache2/www-access.log) permitió identificar la presencia de un User-Agent anómalo, el cual no corresponde a tráfico legítimo de usuario final:

```
checho@Windows-localhost:~/Hammered$ cat apache2/www-access.log | cut -d ' ' -f 12 | sort | uniq
"-"
"Apple-PubSub/65.12.1"
"Mozilla/4.0
"Mozilla/5.0
"WordPress/2.9.2;
"pxyscand/2.1"
```

El campo **User-Agent** en los logs HTTP identifica el cliente que realiza la solicitud al servidor. En condiciones normales, este valor corresponde a:

- navegadores web (Chrome, Firefox, etc.)
- aplicaciones legítimas
- bots conocidos (Googlebot, etc.)

Sin embargo, el valor identificado: `pxyscand/2.1` presenta características claramente atípicas de no corresponder a ningún navegador estándar.

"pxyscand" sugiere con alta probabilidad que se trata de una herramienta automatizada de escaneo que opera a través de un proxy.

Basado en la evidencia, es razonable inferir que el atacante utilizó un proxy o red de proxies para ejecutar escaneos y posiblemente interactuar con el sistema comprometido, reduciendo la probabilidad de detección y bloqueo.

---

9. Problemas de seguridad de la base de datos

El análisis de los registros del sistema (daemon.log) reveló múltiples advertencias relacionadas con el servicio MySQL, las cuales indican una configuración insegura persistente y posibles problemas de integridad en la base de datos.

1. Advertencia crítica: cuentas root sin contraseña

```
checho@Windows-localhost:~/Hammered$ grep "mysql" daemon.log | grep "WARNING"
Mar 18 10:18:42 app-1 /etc/mysql/debian-start[7566]: WARNING: mysql.user contains 2 root accounts without password!
Mar 18 17:01:44 app-1 /etc/mysql/debian-start[14717]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 13:49:49 app-1 /etc/mysql/debian-start[5599]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 18:43:41 app-1 /etc/mysql/debian-start[4755]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 18:45:25 app-1 /etc/mysql/debian-start[4749]: WARNING: mysql.user contains 2 root accounts without password!
Mar 25 11:56:53 app-1 /etc/mysql/debian-start[4848]: WARNING: mysql.user contains 2 root accounts without password!
Apr 14 14:44:34 app-1 /etc/mysql/debian-start[5369]: WARNING: mysql.user contains 2 root accounts without password!
Apr 14 14:44:36 app-1 /etc/mysql/debian-start[5624]: WARNING: mysqlcheck has found corrupt tables
Apr 18 18:04:00 app-1 /etc/mysql/debian-start[4647]: WARNING: mysql.user contains 2 root accounts without password!
Apr 24 20:21:24 app-1 /etc/mysql/debian-start[5427]: WARNING: mysql.user contains 2 root accounts without password!
Apr 28 07:34:26 app-1 /etc/mysql/debian-start[4782]: WARNING: mysql.user contains 2 root accounts without password!
Apr 28 07:34:27 app-1 /etc/mysql/debian-start[5032]: WARNING: mysqlcheck has found corrupt tables
May  2 23:05:54 app-1 /etc/mysql/debian-start[4774]: WARNING: mysql.user contains 2 root accounts without password!
```

Esta advertencia indica que en la tabla interna **mysql.user** existen dos cuentas con privilegios root sin contraseña configurada.

En MySQL, el usuario **root** tiene:

- Privilegios administrativos completos
- Acceso a todas las bases de datos
- Capacidad de crear/modificar usuarios
- Ejecución de operaciones críticas

Impacto de seguridad

La ausencia de contraseña en cuentas root implica:

- Cualquier usuario pueda local (o remoto, si está expuesto) puede conectarse sin la necesidad de credenciales
- Control total de la base de datos permitiéndole al atacante (leer información confidencial, modificar registros, eliminar base de datos, creación de nuevos usuarios con privilegios)

---

10. Mapeo al Marco MITRE ATT&CK

Táctica	Técnica	ID	Descripción	Evidencia
Initial Access	Brute Force	T1110	Múltiples intentos fallidos indican ataque de fuerza bruta	`authentication failure` en `SSH`
Initial Access	Valid Accounts	T1078	Uso de credenciales válidas tras el brute force	`Accepted password for root` en `auth.log`
Privilege Escalation	Valid Accounts	T1078	Acceso directo como root	El atacante obtiene privilegios máximos sin escalación
Persistence	Create Account	T1136.001	Creación de cuenta local para mantener acceso	Usuario `wind3str0y` creado
Defense Evasion	Modify System Firewall	T1562.004	Configuración de reglas para acceso persistente	`iptables -A INPUT`
Execution	Command and Scripting Interpreter	T1059	Uso de shell interactiva para ejecutar comandos	`/bin/bash`
Discovery	Network Service Discovery	T1046	Escaneo de red para identificar servicios	Instalación de `nmap`
Command and Control	Proxy	T1090	Uso de proxy para ocultar origen	`pxyscand/2.1`
Credential Access	Unsecured Credentials	T1552	Credenciales expuestas sin autenticación	`WARNING: mysql.user contains 2`

				`root accounts without password!`

---

11. Conclusiones

En conjunto, los hallazgos evidencian que el incidente no se limitó a un acceso no autorizado puntual, sino que evolucionó hacia un compromiso sostenido del sistema, donde el atacante logró establecer persistencia, evadir controles de seguridad, ejecutar actividades de reconocimiento y potencialmente afectar la integridad de la información. Este tipo de comportamiento es característico de un ataque completo, que abarca múltiples fases del ciclo de vida de una intrusión, desde el acceso inicial hasta la explotación y mantenimiento del control.

En términos de impacto, se concluye que el sistema debe considerarse completamente comprometido, lo que implica que no se puede garantizar la integridad ni la confiabilidad de sus componentes. En un entorno real, este nivel de compromiso requeriría acciones inmediatas de contención, erradicación y recuperación, incluyendo la reconstrucción del sistema desde fuentes confiables, la rotación de credenciales y la implementación de controles de seguridad reforzados.

Finalmente, este caso pone de manifiesto cómo la combinación de credenciales débiles, configuraciones inseguras y falta de controles de monitoreo puede facilitar la ejecución exitosa de un ataque relativamente común, pero con consecuencias críticas. Asimismo, resalta la importancia de adoptar un enfoque de defensa en profundidad, donde múltiples capas de seguridad permitan detectar, prevenir y responder eficazmente ante este tipo de amenazas.